PHISHING SIMULATION & QUANTITATIVE RISK ASSESSMENT

Lab 3A | GlobalTech Inc. | Executive briefing for the Board, CISO and CFO

Prepared by: Adediran Eunice Adebukola Registration: C11-26-CGRCE-17595 Date: 1 November 2026

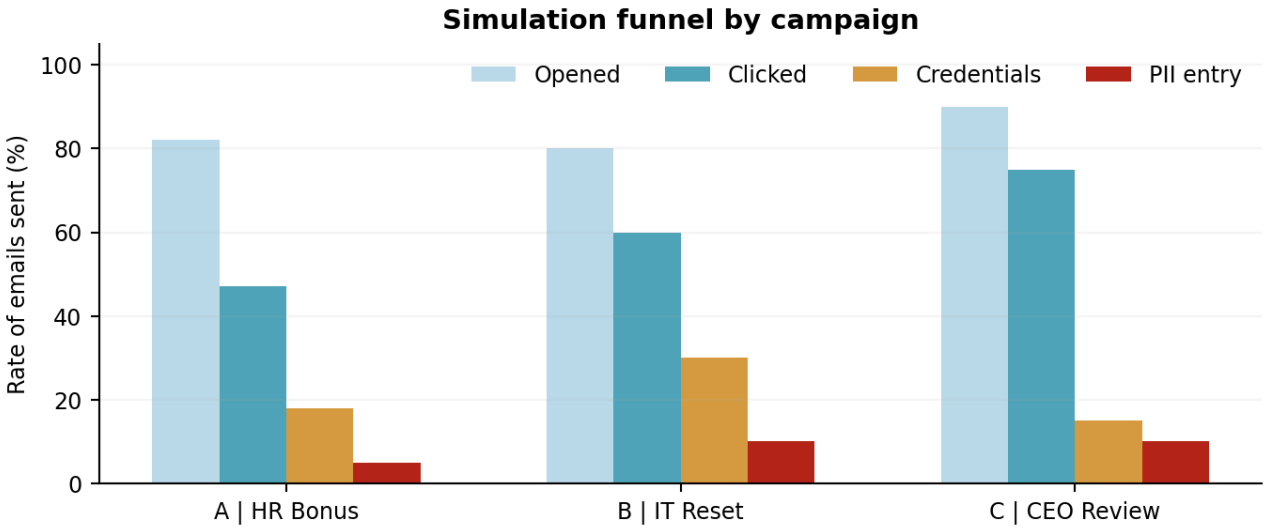
1. Executive summary

Three simulated phishing campaigns sent 430 emails, generated 257 clicks and resulted in 105 credential submissions. The email-weighted credential submission rate was 24.42%. Campaign B (IT System Password Reset) was the most successful by credential submission rate at 30%.

Applying the brief's simplified extrapolation gives a $652.5M Campaign B exposure. However, the supplied 25% breach probability is conditional on stolen credentials and has no stated time horizon; 150 expected incidents is not an observed annual frequency. Treat all dollar exposures and very high ROI estimates as scenario outputs, not validated loss forecasts.

2. Phase 1 — fundamental phishing metrics

Campaign	Opened / sent	Clicked / sent	Credentials / sent	PII / sent
A — HR Bonus	82.0%	47.0%	18.0%	5.0%
B — IT Reset	80.0%	60.0%	30.0%	10.0%
C — CEO Review	90.0%	75.0%	15.0%	10.0%
Weighted overall	82.33%	59.77%	24.42%	8.84%



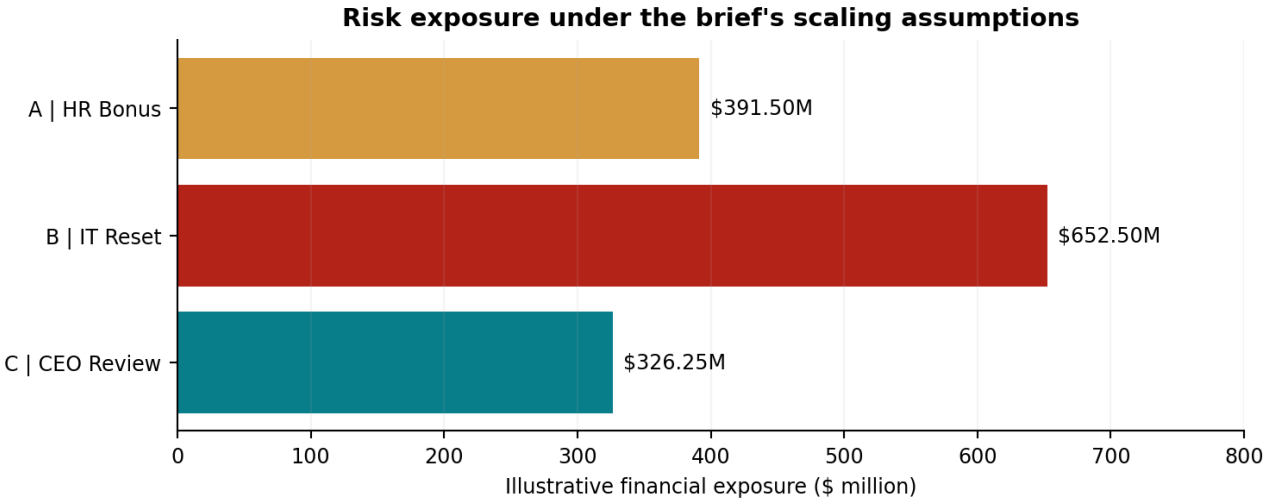
Stage conversion: Open-to-click: A 57.32%, B 75.00%, C 83.33%. Post-click credential submission: A 38.30%, B 50.00%, C 20.00%. The brief's "22.1% overall credential theft" does not match 105/430 = 24.42%.

3. Phase 2 — risk quantification

Exercise formula: projected compromised accounts = 2,000 × (credentials submitted / emails sent). Expected breach events = projected compromised accounts × 25%. Scenario exposure = expected events × $4,350,000.

Campaign	Projected stolen	Expected events	Corrected exposure	Brief exposure
A — HR Bonus	360	90	$391.50M	$156.60M
B — IT Reset	600	150	$652.50M	$652.50M
C — CEO Review	300	75	$326.25M	$104.40M

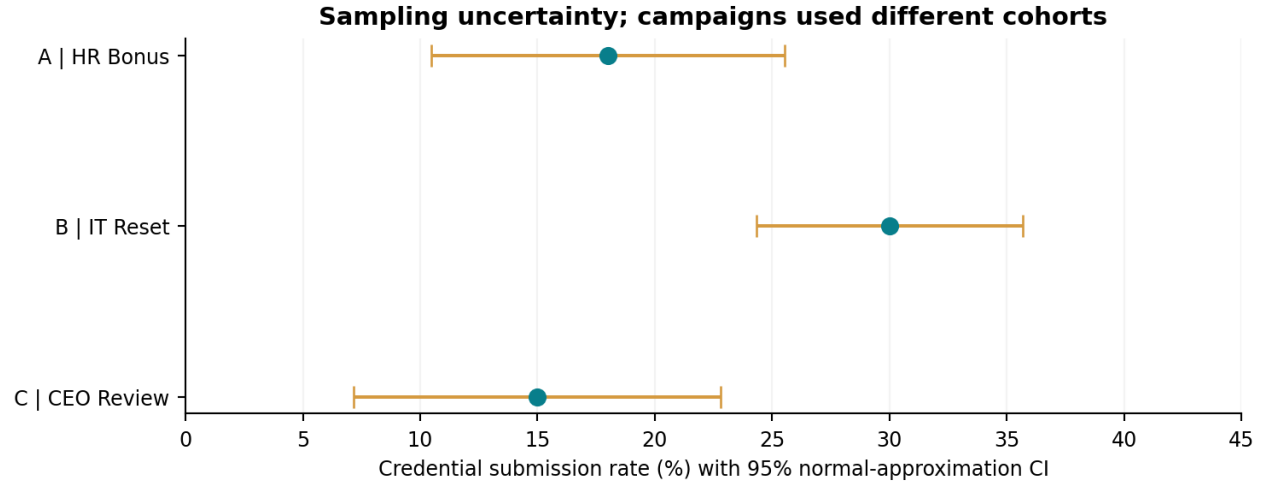
Reconciliation: Campaign A and C exposures in the original brief do not follow its stated 25% probability; the corrected values are $391.5M and $326.25M. Campaign C was tested on executives/assistants, so extrapolating its response rate to all employees is particularly uncertain. These scenarios are not additive.



4. Phase 3 — statistical uncertainty

Using the brief's 95% normal-approximation interval, $p \pm 1.96 \times \sqrt{[p(1-p)/n]}$:

Campaign	Rate	n	Margin	95% interval
A — HR Bonus	18.0%	100	7.53 pp	10.47%–25.53%
B — IT Reset	30.0%	250	5.68 pp	24.32%–35.68%
C — CEO Review	15.0%	80	7.82 pp	7.18%–22.82%

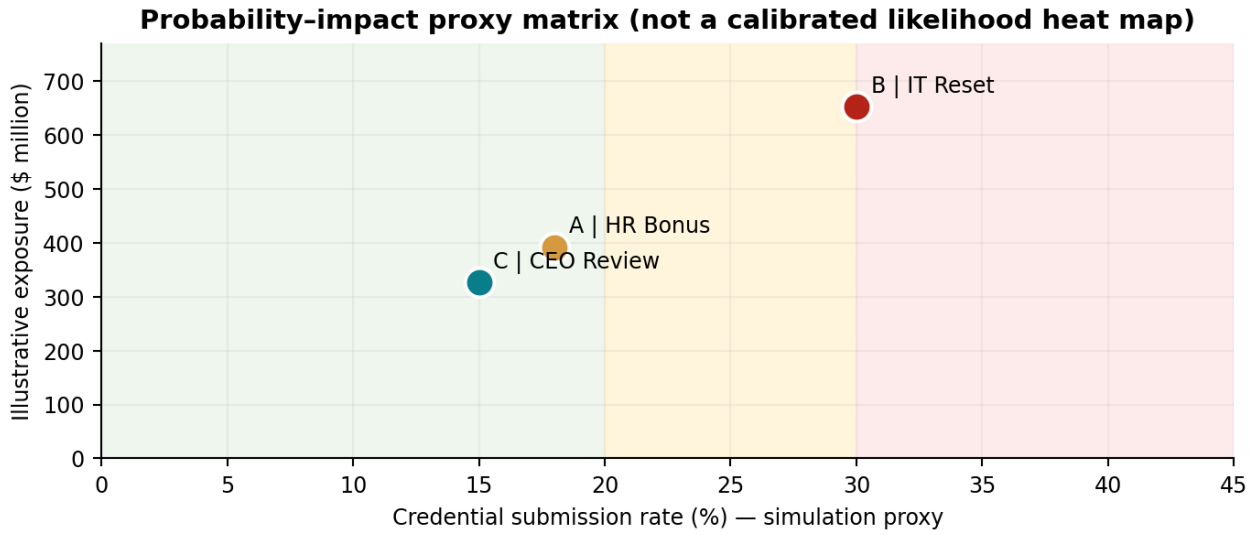


Intervals assume approximately independent, representative observations. Different phishing themes and target populations mean observed differences are not proof of campaign-theme causality.

5. Phase 3 — risk assessment and priority

Rank by model	Campaign	Brief risk label	Action
1	B — IT Reset	CRITICAL	Immediate phishing-resistant MFA and IT-reset verification
2	A — HR Bonus	MEDIUM-HIGH	Targeted awareness and credential controls
3	C — CEO Review	HIGH	Executive-focused training and identity protection

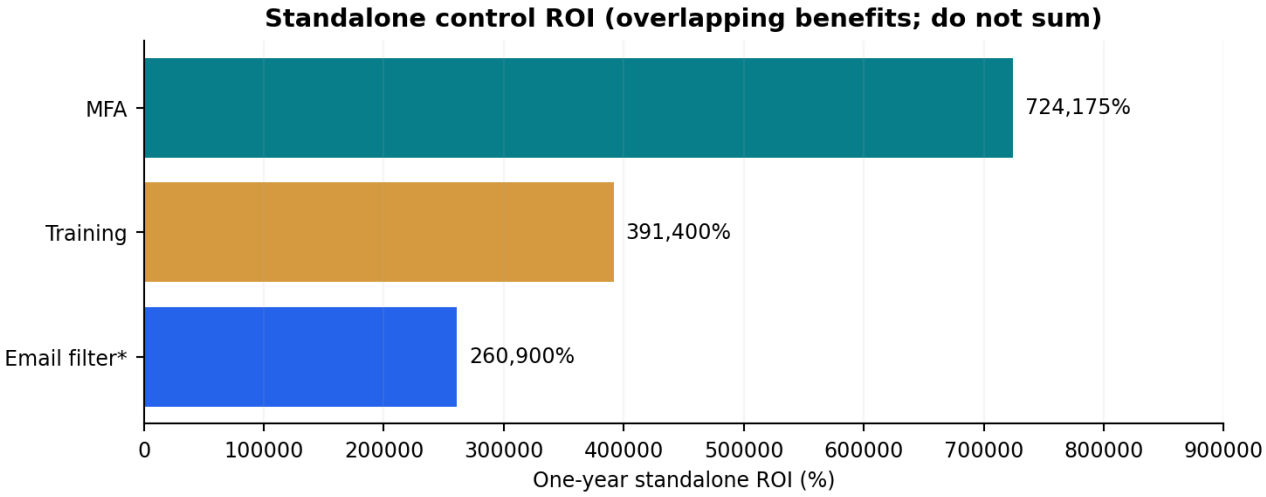
The numeric rank reflects corrected illustrative exposure, not a validated likelihood score. The original brief assigns priority “2” to both A and C; executive targeting also warrants attention independent of modelled dollars.



6. Phase 2 — standalone control cost-benefit

Control	Initial cost	Assumed reduction	Avoided exposure	1-year ROI
MFA	$90,000	99.9%	$651.85M	724,175%
Training	$100,000	60.0%	$391.50M	391,400%
Email filtering*	$50,000	20.0%	$130.50M	260,900%

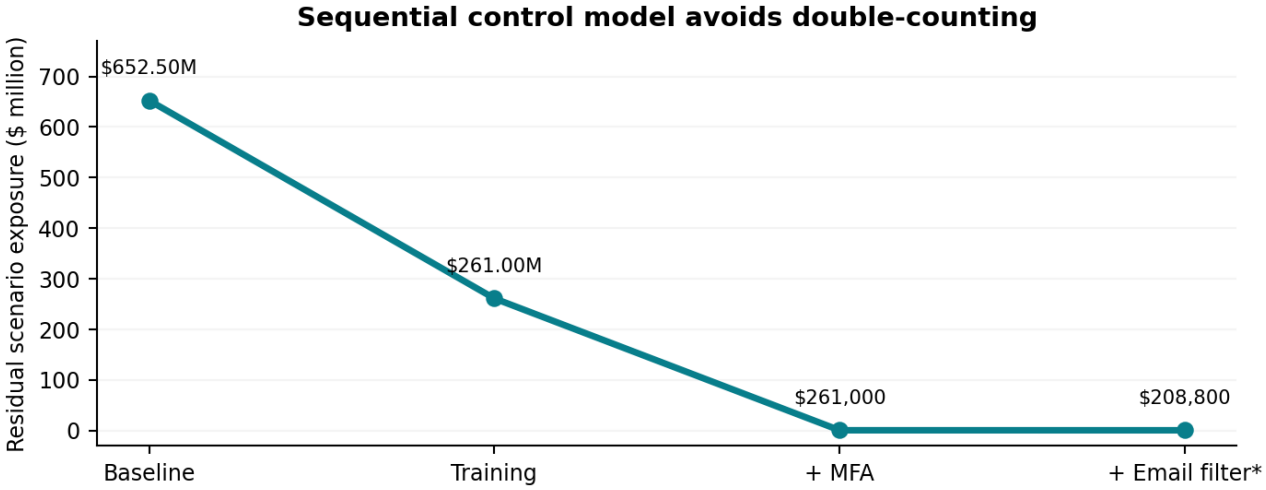
ROI: (annual avoided exposure − initial cost) / initial cost. Payback: initial cost / annual avoided exposure. Both assume a one-year horizon and uniform annual benefit; annual maintenance and deployment timing are not provided. Filtering efficacy (*) is an analyst assumption inferred from the brief’s example, not a supplied effectiveness estimate.



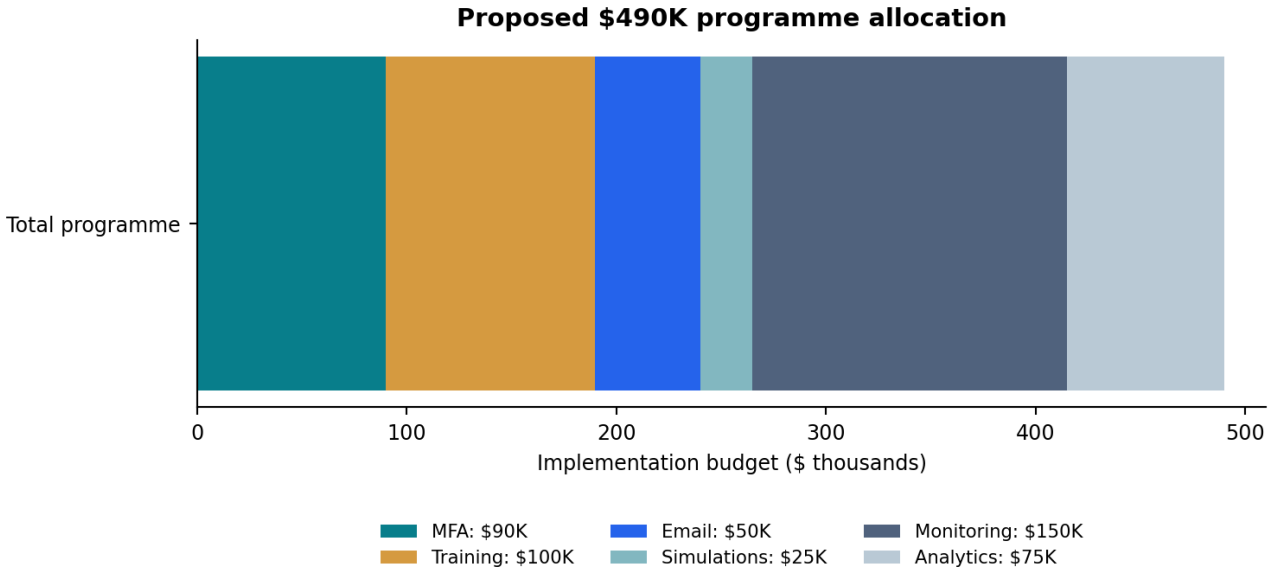
7. Combined controls and financial justification

Standalone control savings overlap and must not be added. The sequential model applies a 60% reduction in click activity (holding the 50% post-click credential conversion constant), followed by 99.9% MFA impact reduction and an assumed further 20% email-filter reduction.

Stage	Residual exposure	Avoided from prior stage
Campaign B baseline	$652,500,000	—
After training	$261,000,000	$391,500,000
After MFA	$261,000	$260,739,000
After email filtering	$208,800	$52,200

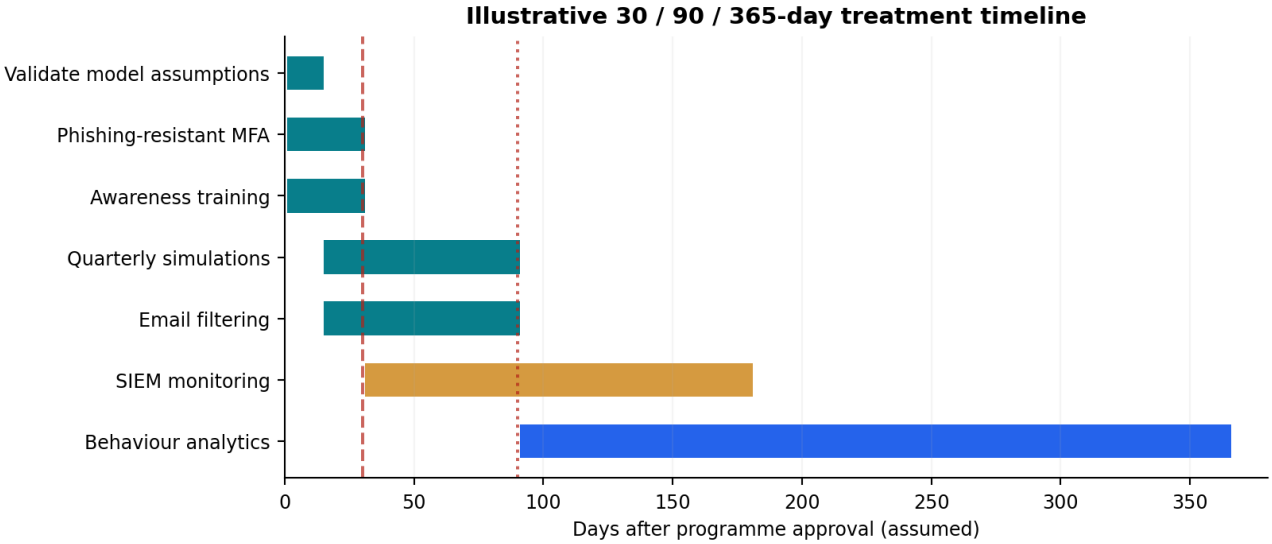


Quantified three-control cost: $240,000. Full six-initiative budget: $490,000 (MFA $90K, training $100K, filtering $50K, simulations $25K, monitoring $150K, analytics $75K). Illustrative full-programme net avoided exposure: $651,801,200; the additional three initiatives are not assigned invented dollar benefits.



8. Treatment timeline and acceptance criteria

Dates are relative to programme approval, not committed implementation dates. Ownership is proposed and must be confirmed.



Period	Proposed action	Evidence for completion
Days 1–30	Confirm assumptions; deploy MFA; deliver urgent awareness training	Approved risk model, MFA enforcement reports, completion logs
Days 31–90	Quarterly simulation; email filtering; begin SIEM integration	Cohort-segmented test results, filter telemetry, alert coverage
Days 91–365	Extend monitoring; behavioural analytics; quarterly review	Response SLAs, detection testing, updated risk estimates

9. Recommendations to the CISO and CFO

Approve the initial identity and awareness workstream subject to verification. MFA and training address the demonstrated credential-submission risk; the simulations justify investigation and control strengthening even without a credible $652.5M annual forecast.

Do not use the extreme ROI percentages as a procurement guarantee. Establish an empirical annual incident rate, define what constitutes one major breach, calibrate loss distributions, assess correlated account compromises, and capture ongoing operating costs before final budget sign-off.

Retest: run equivalent campaigns by population, verify MFA resistance to phishing, monitor credential submission and incident outcomes, and update the risk register quarterly.

Appendix — calculation steps and source reconciliation

Campaign A: 18/100 = 18%; 2,000 × 18% = 360 projected compromised accounts; 360 × 25% = 90 expected events; 90 × $4.35M = $391.5M.

Campaign B: 75/250 = 30%; 2,000 × 30% = 600; 600 × 25% = 150; 150 × $4.35M = $652.5M.

Campaign C: 12/80 = 15%; 2,000 × 15% = 300; 300 × 25% = 75; 75 × $4.35M = $326.25M.

Training arithmetic correction: Campaign B click rate is 150/250 = 60%, not 30%. After a 60% reduction, click rate = 60% × 40% = 24%. Holding the 50% post-click credential rate fixed gives 12% credentials, 240 projected accounts, 60 expected events, and $261M scenario exposure. The brief reaches $261M but mislabels the starting 30% as a click rate.

MFA: $652.5M × 99.9% = $651.8475M avoided; ($651.8475M − $90K)/$90K × 100 = 724,175% one-year ROI.

Training: $652.5M × 60% = $391.5M avoided; ($391.5M − $100K)/$100K × 100 = 391,400%.

Email filtering: $652.5M × assumed 20% = $130.5M avoided; ($130.5M − $50K)/$50K × 100 = 260,900%, not the brief’s 260,800%.

Combined model: $652.5M × 0.4 × 0.001 × 0.8 = $208,800 residual. Full-programme ROI = (($652,500,000 − $208,800) − $490,000) / $490,000 × 100 = 133,020.65%. This is an arithmetic scenario only.

Bonus break-even: $490,000 / $4,350,000 per breach = 0.1126 expected major breaches. In discrete terms, preventing one breach of the stated severity would exceed the programme cost. This assumes a comparable event and full loss avoided.

Unsupported brief statements: 93.75% “breach probability” is not derived from the supplied inputs; the claimed 90% post-control reduction and $65M residual conflict with 99.9% MFA efficacy; industry benchmarks are unreferenced. See the workbook’s Source Reconciliation sheet.

Source: User-supplied “Lab 3A.docx”, Lab 3: Advanced GRC Phishing Simulation & Quantitative Risk Analysis, pp. 1–8. Analyst assumptions and corrections are explicitly labelled.